



Muneeb Ahmed

CSI-B1-358

Topic : Network Enumeration & Service

Vulnerability Discovery

Executive Summary

This report documents the activities performed during the network reconnaissance and enumeration phase of a controlled security assessment. The primary objective of the tasks was to understand how attackers and security analysts identify active hosts, open ports, running services, and potential vulnerabilities within a network environment. The exercises were conducted using the network scanning tool Nmap against authorized lab targets, including the intentionally vulnerable virtual machine Metasploitable 2.

The first phase involved performing port scanning to identify accessible network services. Different scanning techniques such as SYN scanning, TCP connect scanning, and UDP scanning were explored to understand how various protocols behave during reconnaissance. These scans helped identify open ports and services running on the target system. Identifying open ports is a critical step because each open port represents a potential entry point that an attacker could attempt to exploit.

The second phase focused on service fingerprinting and banner grabbing. Using Nmap's version detection and aggressive scanning capabilities, the services running on open ports were identified along with their associated versions. Manual banner grabbing techniques were also performed using tools like Netcat and Telnet to observe how servers disclose information when connections are established. This information is important because outdated service versions often contain publicly known vulnerabilities.

The third phase involved using the Nmap Scripting Engine (NSE) to automate deeper enumeration and vulnerability discovery. Scripts from the discovery and safe categories were executed to gather additional network information such as DHCP configuration, router identification, multicast services, and device details. Vulnerability scripts were also used to detect known weaknesses associated with running services. The detected vulnerabilities were then mapped to publicly known identifiers from the MITRE Common Vulnerabilities and Exposures database. Mapping findings to CVE identifiers helps security analysts understand the severity, impact, and mitigation recommendations for each vulnerability.

The final phase explored stealth scanning and firewall evasion techniques. Several advanced Nmap options were used to observe how packet manipulation affects detection by network defenses. Techniques such as packet fragmentation, MTU manipulation, decoy scanning, and source port spoofing were tested. These techniques demonstrate how attackers may attempt to bypass basic firewalls or intrusion detection systems by modifying packet structures or disguising the origin of scan traffic. While modern security systems are generally capable of detecting such behavior, these experiments highlight the importance of robust monitoring and layered defense mechanisms.

Overall, the tasks provided practical experience in network reconnaissance, service enumeration, vulnerability identification, and scan evasion techniques. The exercises demonstrated how security professionals gather information about target systems and how defensive technologies attempt to

detect or block such activity. The results emphasize the importance of properly configured firewalls, updated services, and continuous monitoring to reduce potential attack surfaces and improve the overall security posture of an organization.

Phase 01 : Advance network scanning with NMAP

1- TCP Connect Scan (-sT)

A TCP connect scan completes a full TCP connection using TCP 3 way handshake.

TCP 3-Way Handshake

1. Client → SYN

Client asks the server to start a connection.

2. Server → SYN-ACK

The server acknowledges the request.

3. Client → ACK

Client confirms → Connection established.

Because the connection is fully established, the target system logs the connection

Command : `nmap -sT -p 1-1000 -oN results_sT.txt hackthisiste.org`

```
(kali@kali)-[~/Desktop/Cyberster/week02]
$ nmap -sT -p 1-1000 -oN results_sT.txt hackthissite.org
Starting Nmap 7.95 ( https://nmap.org ) at 2026-03-11 05:37 EDT
Nmap scan report for hackthissite.org (137.74.187.100)
Host is up (0.0017s latency).
Other addresses for hackthissite.org (not scanned): 137.74.187.102 137.74.187.101 137.74.187.104 137.74.187.103
All 1000 scanned ports on hackthissite.org (137.74.187.100) are in ignored states.
Not shown: 1000 filtered tcp ports (no-response)

Nmap done: 1 IP address (1 host up) scanned in 23.47 seconds
```

Understanding the scanned output :

What Nmap returned - Host is up (0.0017s latency), All 1000 scanned ports are in ignored states, Not shown: 1000 filtered tcp ports (no-response)

Result	Explanation
Host is up	The server responded to network probes
0.0017s latency	Very fast response time
1000 filtered ports	A firewall blocked the scan
no-response	Packets were silently dropped

So Nmap did not detect any open ports because a firewall or IDS is filtering them.

2- SYN Stealth Scan (-sS)

A SYN Scan is called Stealth Scan. Instead of completing the handshake, it stops halfway.

How it works

1. Client → SYN
2. Server → SYN-ACK
3. Client → RST (reset)

Connection is never fully established.

Because of this: Faster, Harder to detect, Preferred in red team assessments

Command: `sudo nmap -sS -p 1-1000 -oN results_sS.txt hackthisiste.org`

```
(kali@kali)-[~/Desktop/Cyberster/week02]
$ sudo nmap -sS -p 1-1000 -oN results_sS.txt hackthisiste.org
[sudo] password for kali:
Starting Nmap 7.95 ( https://nmap.org ) at 2026-03-11 05:57 EDT
Nmap scan report for hackthisiste.org (137.74.187.100)
Host is up (0.016s latency).
Other addresses for hackthisiste.org (not scanned): 137.74.187.104 137.74.187.102 137.74.187.101 137.74.187.103
Not shown: 997 filtered tcp ports (no-response)
PORT      STATE SERVICE
22/tcp    closed ssh
80/tcp    open  http
443/tcp    open  https

Nmap done: 1 IP address (1 host up) scanned in 13.35 seconds
```

Understanding the scanned output :

997 Filtered Ports : These ports were blocked by a firewall or filtering system,

Port 22 – SSH (closed) meaning the service is not accepting connections,

Port 80/443 - HTTP & HTTPS (open) meaning the server is running a web application.

Other results :

Parameter	Result
Host status	Up
Latency	0.016s
Filtered ports	997
Scan duration	13.35 seconds

3- UDP Scan (-sU)

This scans UDP services. UDP is used by many important services like DNS - port 53, SNMP - port 161, DHCP - port 67, NTP - port 153.

UDP is harder to scan because there is no handshake. If there is no response, Nmap marks the port as: open | filtered

Command : `sudo nmap -sU --top-port 1000 -oN results_sU.txt`
hackthissite.org

```
(kali㉿kali)-[~/Desktop/Cyberster/week02]
└─$ sudo nmap -sU --top-ports 1000 -oN results_sU.txt hackthissite.org
[sudo] password for kali:
Starting Nmap 7.95 ( https://nmap.org ) at 2026-03-11 06:24 EDT
Nmap scan report for hackthissite.org (137.74.187.102)
Host is up (0.0036s latency).
Other addresses for hackthissite.org (not scanned): 137.74.187.104 137.74.187.101 137.74.187.100 137.74.187.103
All 1000 scanned ports on hackthissite.org (137.74.187.102) are in ignored states.
Not shown: 1000 open|filtered udp ports (no-response)

Nmap done: 1 IP address (1 host up) scanned in 5.27 seconds
```

Understanding the output :

Output summary :

All 1000 scanned ports are in ignored states, Not shown: 1000 open|filtered
udp ports (no-response)

What this means

Result	Explanation
Host is up	Target responded to probes
open filtered	Nmap cannot determine if port is open or blocked
no-response	Target did not reply to UDP packets

Why UDP Shows open|filtered: Unlike TCP, UDP does not use a handshake.

UDP works like this:

Client → UDP packet

Server → Optional response

If the server does not reply, Nmap cannot determine whether:

- The port is open
- The port is filtered by a firewall

So it marks it as: open|filtered

4 - Comparison of -sT vs -sS vs -sU

Scan Type	Protocol	Speed	Detectability	Purpose
-sT	TCP	Medium	High	Basic scanning
-sS	TCP	Fast	Low	Professional pentesting
-sU	UDP	Slow	Medium	Discover UDP services

Why Red Teamers Prefer -sS

In red teaming, the goal is to simulate a real attacker while avoiding detection.

Red teamers prefer SYN scans (-sS) because:

- 1 - Stealth:** It does not complete the TCP connection, so fewer logs are generated.
- 2 - Faster scanning:** It avoids full connection setup, making it quicker than -sT.
- 3 - Harder for IDS to detect:** Many security systems monitor full TCP sessions, not half-open ones.
- 4 - Efficient reconnaissance:** Allows attackers to quickly map open ports before exploitation.

5 - What timing templates are

Timing templates control how fast Nmap sends packets during scanning.

If Nmap sends packets too fast, it might:

- Miss ports
- Trigger firewalls or IDS
- Produce unreliable results

If it sends packets slowly, it becomes:

- More stealthy
- More accurate
- But much slower

Nmap Timing Levels (-T0 to -T5)

Timing	Name	Speed	Purpose
-T0	Paranoid	Extremely slow	IDS evasion
-T1	Sneaky	Very slow	Avoid detection

-T2	Polite	Slow	Reduce network load
-T3	Normal	Default	Balanced scanning
-T4	Aggressive	Fast	Used in pentesting
-T5	Insane	Very fast	Risky, may miss ports

```

(kali㉿kali)-[~/Desktop/Cyberster/week02]
└─$ sudo nmap -sT -T0 -p 1-1000 -oN results_sT_2.txt hackthissite.org
[sudo] password for kali:
Starting Nmap 7.95 ( https://nmap.org ) at 2026-03-11 07:05 EDT

(kali㉿kali)-[~/Desktop/Cyberster/week02]
└─$ sudo nmap -sT -T2 -p 1-1000 -oN results_sT_2.txt hackthissite.org
Starting Nmap 7.95 ( https://nmap.org ) at 2026-03-11 07:15 EDT

(kali㉿kali)-[~/Desktop/Cyberster/week02]
└─$ sudo nmap -sT -T5 -p 1-1000 -oN results_sT_2.txt hackthissite.org
Starting Nmap 7.95 ( https://nmap.org ) at 2026-03-11 07:25 EDT
Nmap scan report for hackthissite.org (137.74.187.103)
Host is up (0.0017s latency).
Other addresses for hackthissite.org (not scanned): 137.74.187.102 137.74.187.101 137.74.187.104 137.74.187.100
All 1000 scanned ports on hackthissite.org (137.74.187.103) are in ignored states.
Not shown: 1000 filtered tcp ports (no-response)

Nmap done: 1 IP address (1 host up) scanned in 14.51 seconds

```

Command : sudo nmap -sS -T2 -p 1-1000 -oN results_sT_2.txt
hackthissite.org

It nearly took 3257 seconds (54 minutes) to scan.

Command : sudo nmap -sS -T4 -p 1-1000 -oN results_sT_2.txt
hackthissite.org

It took only 8 seconds to scan.

```
(kali@kali)-[~/Desktop/Cyberster/week02]
$ sudo nmap -sS -T2 -p 1-1000 -oN results_sT_2.txt hackthissite.org
Starting Nmap 7.95 ( https://nmap.org ) at 2026-03-11 07:26 EDT
Stats: 0:26:26 elapsed; 0 hosts completed (1 up), 1 undergoing SYN Stealth Scan
SYN Stealth Scan Timing: About 49.83% done; ETC: 08:19 (0:26:37 remaining)
Stats: 0:26:40 elapsed; 0 hosts completed (1 up), 1 undergoing SYN Stealth Scan
SYN Stealth Scan Timing: About 50.27% done; ETC: 08:19 (0:26:23 remaining)
Stats: 0:32:22 elapsed; 0 hosts completed (1 up), 1 undergoing SYN Stealth Scan
SYN Stealth Scan Timing: About 60.53% done; ETC: 08:20 (0:21:06 remaining)
Stats: 0:34:28 elapsed; 0 hosts completed (1 up), 1 undergoing SYN Stealth Scan
SYN Stealth Scan Timing: About 64.30% done; ETC: 08:20 (0:19:08 remaining)
Stats: 0:37:25 elapsed; 0 hosts completed (1 up), 1 undergoing SYN Stealth Scan
SYN Stealth Scan Timing: About 69.63% done; ETC: 08:20 (0:16:19 remaining)
Stats: 0:53:28 elapsed; 0 hosts completed (1 up), 1 undergoing SYN Stealth Scan
SYN Stealth Scan Timing: About 98.57% done; ETC: 08:20 (0:00:47 remaining)
Nmap scan report for hackthissite.org (137.74.187.104)
Host is up (0.16s latency).
Other addresses for hackthissite.org (not scanned): 137.74.187.102 137.74.187.103 137.74.187.100 137.74.187.101
Not shown: 997 filtered tcp ports (no-response)
PORT      STATE SERVICE
22/tcp    closed ssh
80/tcp    open  http
443/tcp    open  https

Nmap done: 1 IP address (1 host up) scanned in 3257.62 seconds

(kali@kali)-[~/Desktop/Cyberster/week02]
$ sudo nmap -sS -T4 -p 1-1000 -oN results_sT_2.txt hackthissite.org
[sudo] password for kali:
Starting Nmap 7.95 ( https://nmap.org ) at 2026-03-11 08:21 EDT
Nmap scan report for hackthissite.org (137.74.187.103)
Host is up (0.021s latency).
Other addresses for hackthissite.org (not scanned): 137.74.187.100 137.74.187.101 137.74.187.102 137.74.187.104
Not shown: 998 filtered tcp ports (no-response)
PORT      STATE SERVICE
80/tcp    open  http
443/tcp    open  https

Nmap done: 1 IP address (1 host up) scanned in 8.14 seconds
```

Phase 02 : Service fingerprinting & banner grabbing

Service fingerprinting : identifying what services and versions are running on open ports after you discovered them.

Banner grabbing : A banner is the information a server sends when a connection is made

1- Service version detection

The -sV option tells Nmap to probe open ports to identify:

- Service name
- Software running
- Version of the software

This helps determine if the service might have known vulnerabilities.

Command: `nmap -sV hackthissite.org`

You can also scan specific ports: `nmap -sV -p 80,443 hackthissite.org`

```
(kali@kali)-[~/Desktop/Cyberster/week02]
$ nmap -sV hackthissite.org
Starting Nmap 7.95 ( https://nmap.org ) at 2026-03-12 02:23 EDT
Nmap scan report for hackthissite.org (137.74.187.100)
Host is up (0.021s latency).
Other addresses for hackthissite.org (not scanned): 137.74.187.103 137.74.187.101 137.74.187.102 137.74.187.104
Not shown: 998 filtered tcp ports (no-response)
PORT      STATE SERVICE      VERSION
80/tcp    open  http-proxy   HAProxy http proxy 1.3.1 - 1.9.0
443/tcp   open  ssl/http-proxy HAProxy http proxy 1.3.1 - 1.9.0
Service Info: Device: load balancer

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 60.87 seconds
```

2- Aggressive scan

Aggressive scan enables multiple advanced features at once.

Command: `sudo nmap -A hackthissite.org`

What -A enables

Feature	Purpose
OS Detection	Guess the operating system
Version Detection	Detect service versions
Script Scanning	Run security scripts
Traceroute	Show network path to target

```
(kali@kali)-[~/Desktop/Cyberster/week02]
└─$ sudo nmap -A hackthissite.org
[sudo] password for kali:
Starting Nmap 7.95 ( https://nmap.org ) at 2026-03-12 02:39 EDT
Nmap scan report for hackthissite.org (137.74.187.104)
Host is up (0.021s latency).
Other addresses for hackthissite.org (not scanned): 137.74.187.102 137.74.187.100 137.74.187.101 137.74.187.103
Not shown: 998 filtered tcp ports (no-response)
PORT      STATE SERVICE        VERSION
80/tcp    open  http-proxy     HAProxy http proxy 1.3.1 - 1.9.0
|_http-open-proxy: Proxy might be redirecting requests
443/tcp   open  ssl/http-proxy HAProxy http proxy 1.3.1 - 1.9.0
|_ssl-cert: Subject: commonName=hackthisjogneh42n5o7gbzrewxee3vyu6ex37ukyvdw6jm66npakiyd.onion
| Subject Alternative Name: DNS:hackthissite.org, DNS:www.hackthissite.org, DNS:hackthisjogneh42n5o7gbzrewxee3vyu6ex37ukyvdw6jm66npakiyd.onion
|_ Not valid before: 2025-03-25T04:43:22
|_ Not valid after: 2026-03-25T04:43:22
Warning: OSScan results may be unreliable because we could not find at least 1 open and 1 closed port
Device type: VOIP adapter|bridge|general purpose
Running (JUST GUESSING): AT&T embedded (93%), Oracle Virtualbox (92%), Slirp (92%), QEMU (90%)
OS CPE: cpe:/o:oracle:virtualbox cpe:/a:danny.gasparovski:slirp cpe:/a:qemu:qemu
Aggressive OS guesses: AT&T BGW210 voice gateway (93%), Oracle Virtualbox Slirp NAT bridge (92%), QEMU user mode network gateway (90%)
No exact OS matches for host (test conditions non-ideal).
Network Distance: 1 hop
Service Info: Device: load balancer

TRACEROUTE (using port 80/tcp)
HOP RTT      ADDRESS
1   0.96 ms  hackthissite.org (137.74.187.104)

OS and Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 117.23 seconds
```

3- Manual banner grabbing

This reveals:

Item	Information
Service	FTP
Software	ProFTPD
Version	1.3.5

Attackers use banners to identify specific vulnerable versions.

Method 1 — Using Netcat

Command : nc hackthissite.org 80

Then type: HEAD / HTTP/1.0

Example response: HTTP/1.1 200 OK Server: Apache/2.4.29

This might reveal : Web Server (Apache) , Version (2.4.29)

```
(kali㉿kali)-[~/Desktop/Cyberster/week02]
$ nc hackthissite.org 80 HEAD / HTTP/1.0
HTTP/1.0 408 Request Time-out
Cache-Control: no-cache
Connection: close
Content-Type: text/html

<html><body><h1>408 Request Time-out</h1>
Your browser didn't send a complete request in time.
</body></html>
invalid port HEAD
```

Method 2 — Using Telnet

Command : Telnet hackthissite.org 80

Then type: HEAD / HTTP/1.0

Example response: HTTP/1.1 200 OK Server: Apache/2.4.29

This might reveal : Web Server (Apache) , Version (2.4.29)

```
(kali㉿kali)-[~/Desktop/Cyberster/week02]
$ telnet hackthissite.org 80
Trying 137.74.187.104 ...
Connected to hackthissite.org.
Escape character is '^]'.
HEAD / HTTP/1.0
HTTP/1.0 408 Request Time-out
Cache-Control: no-cache
Connection: close
Content-Type: text/html

<html><body><h1>408 Request Time-out</h1>
Your browser didn't send a complete request in time.
</body></html>
Connection closed by foreign host.
```

Method 3 — SMB Enumeration (port 445)

If port 445 is open, it usually indicates SMB file sharing on Windows systems.

SMB can reveal lots of sensitive information.

You can enumerate it using Enum4linux.

Command : enum4linux -a hackthissite.org

Information Enum4linux Can Discover : Shared folders (Public,Admin), Users (Admin,Guest), Groups (Domain Users), Domain info (Windows Domain name).

```
(kali㉿kali)-[~/Desktop/Cyberster/week02]
$ enum4linux -a hackthissite.org
Starting enum4linux v0.9.1 ( http://labs.portcullis.co.uk/application/enum4linux/ ) on Fri Mar 13 06:28:58 2026

===== ( Target Information ) =====
Target ..... hackthissite.org
RID Range ..... 500-550,1000-1050
Username ..... ''
Password ..... ''
Known Usernames .. administrator, guest, krbtgt, domain admins, root, bin, none

===== ( Enumerating Workgroup/Domain on hackthissite.org ) =====

[E] Can't find workgroup/domain

===== ( Nbtstat Information for hackthissite.org ) =====

Looking up status of 137.74.187.102
No reply from 137.74.187.102

===== ( Session Check on hackthissite.org ) =====

[E] Server doesn't allow session using username '', password ''. Aborting remainder of tests.
```

Phase 03 : Leveraging NMAP scripting engine

NSE is a scripting framework inside Nmap that allows you to:

- Gather additional service information
- Detect misconfigurations
- Identify vulnerabilities
- Automate security checks

Scripts are grouped into **categories** such as:

Discovery - Gather information about services.

Safe - Non intrusive checks.

Vuln - Identify known vulnerabilities.

PS : For this task and onwards a Metasploitable environment was developed

1- Run Discovery Script

Command : `nmap -script discovery 192.168.0.110`

What discovery script may reveal : service details, DNS information , HTTP headers, network configuration, nearby devices, multicast services, router info.

```

kali@kali:~$ nmap --script discovery 192.168.0.110
Starting Nmap 7.95 ( https://nmap.org ) at 2026-03-13 07:34 EDT
Stats: 0:00:03 elapsed; 0 hosts completed (0 up), 0 undergoing Script Pre-Scan
NSE Timing: About 39.22% done; ETC: 07:34 (0:00:03 remaining)
No profinet devices in the subnet
Pre-scan script results:
| targets-asn:
|_ targets-asn.asn is a mandatory parameter
|_ multicast-profinet-discovery: 0
| broadcast-igmp-discovery:
| 192.168.0.100
|   Interface: eth0
|   Version: 2
|   Group: 224.0.0.251
|   Description: mDNS (rfc6762)
| 192.168.0.103
|   Interface: eth0
|   Version: 2
|   Group: 224.0.0.251
|   Description: mDNS (rfc6762)
| 192.168.0.108
|   Interface: eth0
|   Version: 2
|   Group: 224.0.0.252
|   Description: Link-local Multicast Name Resolution (rfc4795)
| 192.168.0.103
|   Interface: eth0
|   Version: 2
|   Group: 239.255.102.18
|   Description: Organization-Local Scope (rfc2365)
|_ Use the newtargets script-arg to add the results as targets
|_ http-robtex-shared-ns: *TEMPORARILY DISABLED* due to changes in Robtex's API. See https://www.robtex.com/api/
| targets-ipv6-multicast-invalid-dst:
|   IP: fe80::a00:27ff:fe04:6114   MAC: 08:00:27:04:61:14   IFACE: eth0
|   IP: fe80::8087:85ff:fe13:2e43   MAC: 82:87:85:13:2e:43   IFACE: eth0
|   IP: fe80::44ce:ff:fee9:a611   MAC: 46:ce:00:e9:a6:11   IFACE: eth0
|_ Use --script-args=newtargets to add the results as targets
|_ hostmap-robtex: *TEMPORARILY DISABLED* due to changes in Robtex's API. See https://www.robtex.com/api/
| targets-ipv6-multicast-echo:
|   IP: fe80::a00:27ff:fe04:6114   MAC: 08:00:27:04:61:14   IFACE: eth0
|   IP: fe80::8087:85ff:fe13:2e43   MAC: 82:87:85:13:2e:43   IFACE: eth0
|   IP: fe80::44ce:ff:fee9:a611   MAC: 46:ce:00:e9:a6:11   IFACE: eth0
|_ Use --script-args=newtargets to add the results as targets
| targets-ipv6-multicast-slaac:
|   IP: fe80::a00:27ff:fe04:6114   MAC: 08:00:27:04:61:14   IFACE: eth0
|_ Use --script-args=newtargets to add the results as targets
| targets-ipv6-multicast-mld:
|   IP: fe80::a00:27ff:fe04:6114   MAC: 08:00:27:04:61:14   IFACE: eth0
|_ Use --script-args=newtargets to add the results as targets

```

2- Run Safe Script

Command : `nmap --script safe 192.168.0.110`

Safe scripts perform checks that should not disrupt services.

What safe script may reveal : SSL info, service banners, Config details.

```
(kali@kali)-[~]
$ nmap --script safe 192.168.0.110
Starting Nmap 7.95 ( https://nmap.org ) at 2026-03-13 07:45 EDT
No profinet devices in the subnet
Pre-scan script results:
|_eap-info: please specify an interface with -e
|_broadcast-netbios-master-browser:
|_ip server domain
|_broadcast-dhcp-discover:
|_   Response 1 of 1:
|_     Interface: eth0
|_     IP Offered: 192.168.0.111
|_     Server Identifier: 192.168.0.1
|_     Subnet Mask: 255.255.255.0
|_     Router: 192.168.0.1
|_     Domain Name Server: 192.168.0.1
|_lldd-discovery:
|_   192.168.0.1
|_     Hostname: TL-WR740N
|_     Mac: 18:d6:c7:cf:76:3f (TP-Link Technologies)
|_   Use the newtargets script-arg to add the results as targets
|_broadcast-igmp-discovery:
|_   192.168.0.102
|_     Interface: eth0
|_     Version: 2
|_     Group: 224.0.0.251
|_     Description: mDNS (rfc6762)
|_   192.168.0.103
|_     Interface: eth0
|_     Version: 2
|_     Group: 239.255.102.18
|_     Description: Organization-Local Scope (rfc2365)
|_   192.168.0.103
|_     Interface: eth0
|_     Version: 2
|_     Group: 239.255.255.250
|_     Description: Organization-Local Scope (rfc2365)
|_   Use the newtargets script-arg to add the results as targets
|_broadcast-upnp-info:
|_   239.255.255.250
|_     Server: ipos/7.0 UPnP/1.0 TL-WR740N/7.0
|_     Location: http://192.168.0.1:1900/igd.xml
|_multicast-profinet-discovery: 0
|_broadcast-listener:
|_   udp
|_     DHCP
|_       srv ip      cli ip      mask      gw      dns      vendor
|_       192.168.0.1 192.168.0.111 255.255.255.0 192.168.0.1 192.168.0.1 -
|_targets-asn:
|_   targets-asn is a mandatory parameter
|_http-robtext-shared-ns: *TEMPORARILY DISABLED* due to changes in Robtex's API. See https://www.robtext.com/api/
|_hostmap-robtext: *TEMPORARILY DISABLED* due to changes in Robtex's API. See https://www.robtext.com/api/
```

3- Run vuln Script

Command : `nmap -sV --script vuln 192.168.0.110`

This will detect real vulnerabilities on Metasploitable 2.

The output will contain: vulnerable services, exploit information, CVE IDs

```
└─$ sudo nmap -sV --script vuln 192.168.0.110
[sudo] password for kali:
Starting Nmap 7.95 ( https://nmap.org ) at 2026-03-13 08:02 EDT
Stats: 0:01:57 elapsed; 0 hosts completed (1 up), 1 undergoing Script Scan
NSE Timing: About 99.90% done; ETC: 08:04 (0:00:00 remaining)
Nmap scan report for 192.168.0.110
Host is up (0.0010s latency).
Not shown: 977 closed tcp ports (reset)
PORT      STATE SERVICE      VERSION
21/tcp    open  ftp           vsftpd 2.3.4
| ftp-vsftpd-backdoor:
|   VULNERABLE:
|   vsFTPD version 2.3.4 backdoor
|   State: VULNERABLE (Exploitable)
|   IDs: CVE:CVE-2011-2523 BID:48539
|   vsFTPD version 2.3.4 backdoor, this was reported on 2011-07-04.
|   Disclosure date: 2011-07-03
|   Exploit results:
|   Shell command: id
|   Results: uid=0(root) gid=0(root)
|   References:
|   https://github.com/rapid7/metasploit-framework/blob/master/modules/exploits/unix/ftp/vsftpd_234_backdoor.rb
|   http://scarybeastsecurity.blogspot.com/2011/07/alert-vsftpd-download-backdoored.html
|   https://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2011-2523
|   https://www.securityfocus.com/bid/48539
|_ vulners:
|   vsftpd 2.3.4:
|   PACKETSTORM:162145 10.0 https://vulners.com/packetstorm/PACKETSTORM:162145 *EXPLOIT*
|   EDB-ID:49757 10.0 https://vulners.com/exploitdb/EDB-ID:49757 *EXPLOIT*
|   E9B0AEBB-5138-50BF-8922-2D87E3C046DD 10.0 https://vulners.com/githubexploit/E9B0AEBB-5138-50BF-8922-2D87E3C046DD *EXPLOIT*
|   CVE-2011-2523 10.0 https://vulners.com/cve/CVE-2011-2523
|   CNVD-2020-46837 10.0 https://vulners.com/cnvd/CNVD-2020-46837
|   CC3F6C15-182F-53F6-A5CC-812D37F1F047 10.0 https://vulners.com/githubexploit/CC3F6C15-182F-53F6-A5CC-812D37F1F047 *EXPLOIT*
|   A41B5EAD-1A4C-56A6-97C6-1C58A1CF1E3B 10.0 https://vulners.com/githubexploit/A41B5EAD-1A4C-56A6-97C6-1C58A1CF1E3B *EXPLOIT*
|   817CD8FE-87C4-5FE8-B9B2-8CC64333A3F3 10.0 https://vulners.com/githubexploit/817CD8FE-87C4-5FE8-B9B2-8CC64333A3F3 *EXPLOIT*
|   63A5C9A7-C241-5E83-9EE6-ABAB44BDD270 10.0 https://vulners.com/githubexploit/63A5C9A7-C241-5E83-9EE6-ABAB44BDD270 *EXPLOIT*
|   5F4BCEDF-77DF-5D54-851A-0AE8B76458D9 10.0 https://vulners.com/githubexploit/5F4BCEDF-77DF-5D54-851A-0AE8B76458D9 *EXPLOIT*
|   50580586-73C4-5097-81CA-546D6591DF44 10.0 https://vulners.com/githubexploit/50580586-73C4-5097-81CA-546D6591DF44 *EXPLOIT*
|   1337DAY-ID-36095 9.8 https://vulners.com/zdt/1337DAY-ID-36095 *EXPLOIT*
|_ 22/tcp    open  ssh           OpenSSH 4.7p1 Debian 8ubuntu1 (protocol 2.0)
|_ vulners:
|_ cpe:/a:openbsd:openssh:4.7p1:
|   DF059135-2CF5-5441-8F22-E6EF1DEE5F6E 10.0 https://vulners.com/gitee/DF059135-2CF5-5441-8F22-E6EF1DEE5F6E *EXPLOIT*
|   PACKETSTORM:173661 9.8 https://vulners.com/packetstorm/PACKETSTORM:173661 *EXPLOIT*
|   F0979183-AE88-53B4-86CF-3AF0523F3807 9.8 https://vulners.com/githubexploit/F0979183-AE88-53B4-86CF-3AF0523F3807 *EXPLOIT*
|   CVE-2023-38408 9.8 https://vulners.com/cve/CVE-2023-38408
|   CVE-2016-1908 9.8 https://vulners.com/cve/CVE-2016-1908
|   B8190CDB-3EB9-5631-9828-8064A1575B23 9.8 https://vulners.com/githubexploit/B8190CDB-3EB9-5631-9828-8064A1575B23 *EXPLOIT*
|   8FC9C5AB-3968-5F3C-825E-E8DB5379A623 9.8 https://vulners.com/githubexploit/8FC9C5AB-3968-5F3C-825E-E8DB5379A623 *EXPLOIT*
|   8AD01159-548E-546E-AA87-2DE89F3927EC 9.8 https://vulners.com/githubexploit/8AD01159-548E-546E-AA87-2DE89F3927EC *EXPLOIT*
|   6192C35D-F78B-5C0A-AB8D-9826A79A5320 9.8 https://vulners.com/githubexploit/6192C35D-F78B-5C0A-AB8D-9826A79A5320 *EXPLOIT*
|   2227729D-6700-5C8F-8930-1EEAFD4B9FF0 9.8 https://vulners.com/githubexploit/2227729D-6700-5C8F-8930-1EEAFD4B9FF0 *EXPLOIT*
|   0221525F-07F5-5790-912D-F4B9E2D1B587 9.8 https://vulners.com/githubexploit/0221525F-07F5-5790-912D-F4B9E2D1B587 *EXPLOIT*
```

Phase 04 : Stealth and firewall evasion techniques

Normal scans are easy to detect by: Firewalls, IDS, IPS

Systems like Snort or Suricata detect scanning patterns. So attackers sometimes modify how packets are sent.

Part 1 — Packet Fragmentation

Command : `sudo nmap -sS -f 192.168.0.110`

It splits packets into smaller fragments.

Why This Matters

Old firewalls sometimes only inspect the first fragment, meaning the scan could bypass detection.

Modern IDS systems usually reassemble fragments, so this mostly demonstrates network behavior

Part 2 — MTU Manipulation

Command : `sudo nmap -sS -mtu 16 192.168.0.110`

MTU = **Maximum Transmission Unit**

Small packets cause extra fragmentation. This changes how traffic appears to

security systems

Part 3 — Decoy Scanning.

Command : `sudo nmap -sS -D RND:5 192.168.0.110`

What This Does - It inserts fake scanning IP addresses.

Instead of this: Attacker → Target

The target sees: IP1 → Target , IP2 → Target , IP3 → Target , IP4 → Target ,
REAL_IP → Target , IP5 → Target

The system cannot easily identify the real attacker.

Part 4 — Source Port Spoofing

Command : `sudo nmap -sS --source-port 53 192.168.0.110`

What This Means - The scan pretends to come from port 53.

Port 53 is used by the Domain Name System. Since many firewalls trust DNS traffic. So the scan may bypass weak firewall rules.


```
(kali㉿kali)-[~/Desktop/Cyberster/week02]
$ nmap -sS 192.168.0.110
Starting Nmap 7.95 ( https://nmap.org ) at 2026-03-13 10:13 EDT
Nmap scan report for 192.168.0.110
Host is up (0.00044s latency).
Not shown: 977 closed tcp ports (reset)
PORT      STATE SERVICE
21/tcp    open  ftp
22/tcp    open  ssh
23/tcp    open  telnet
25/tcp    open  smtp
53/tcp    open  domain
80/tcp    open  http
111/tcp   open  rpcbind
139/tcp   open  netbios-ssn
445/tcp   open  microsoft-ds
512/tcp   open  exec
513/tcp   open  login
514/tcp   open  shell
1099/tcp  open  rmiregistry
1524/tcp  open  ingreslock
2049/tcp  open  nfs
2121/tcp  open  ccproxy-ftp
3306/tcp  open  mysql
5432/tcp  open  postgresql
5900/tcp  open  vnc
6000/tcp  open  X11
6667/tcp  open  irc
8009/tcp  open  ajp13
8180/tcp  open  unknown
MAC Address: 08:00:27:04:61:14 (PCS Systemtechnik/Oracle VirtualBox virtual NIC)

Nmap done: 1 IP address (1 host up) scanned in 12.04 seconds
```

```
(kali㉿kali)-[~/Desktop/Cyberster/week02]
$ nmap -sS -f 192.168.0.110
Starting Nmap 7.95 ( https://nmap.org ) at 2026-03-13 10:16 EDT
Nmap scan report for 192.168.0.110
Host is up (0.00040s latency).
Not shown: 977 closed tcp ports (reset)
PORT      STATE SERVICE
21/tcp    open  ftp
22/tcp    open  ssh
23/tcp    open  telnet
25/tcp    open  smtp
53/tcp    open  domain
80/tcp    open  http
111/tcp   open  rpcbind
139/tcp   open  netbios-ssn
445/tcp   open  microsoft-ds
512/tcp   open  exec
513/tcp   open  login
514/tcp   open  shell
1099/tcp  open  rmiregistry
1524/tcp  open  ingreslock
2049/tcp  open  nfs
2121/tcp  open  ccproxy-ftp
3306/tcp  open  mysql
5432/tcp  open  postgresql
5900/tcp  open  vnc
6000/tcp  open  X11
6667/tcp  open  irc
8009/tcp  open  ajp13
8180/tcp  open  unknown
MAC Address: 08:00:27:04:61:14 (PCS Systemtechnik/Oracle VirtualBox virtual NIC)

Nmap done: 1 IP address (1 host up) scanned in 1.99 seconds
```

```
(kali㉿kali)-[~/Desktop/Cyberster/week02]
$ nmap -sS -mtu 16 192.168.0.110
Starting Nmap 7.95 ( https://nmap.org ) at 2026-03-13 10:24 EDT
Nmap scan report for 192.168.0.110
Host is up (0.00082s latency).
Not shown: 977 closed tcp ports (reset)
PORT      STATE SERVICE
21/tcp    open  ftp
22/tcp    open  ssh
23/tcp    open  telnet
25/tcp    open  smtp
53/tcp    open  domain
80/tcp    open  http
111/tcp   open  rpcbind
139/tcp   open  netbios-ssn
445/tcp   open  microsoft-ds
512/tcp   open  exec
513/tcp   open  login
```

```

(kali㉿kali)-[~/Desktop/Cyberster/week02]
$ sudo nmap -sS -D RND:5 192.168.0.110
[sudo] password for kali:
Starting Nmap 7.95 ( https://nmap.org ) at 2026-03-13 10:24 EDT
Nmap scan report for 192.168.0.110
Host is up (0.0025s latency).
Not shown: 977 closed tcp ports (reset)
PORT      STATE SERVICE
21/tcp    open  ftp
22/tcp    open  ssh
23/tcp    open  telnet
25/tcp    open  smtp
53/tcp    open  domain
80/tcp    open  http
111/tcp   open  rpcbind
139/tcp   open  netbios-ssn
445/tcp   open  microsoft-ds
512/tcp   open  exec
513/tcp   open  login
514/tcp   open  shell
1099/tcp  open  rmiregistry
1524/tcp  open  ingreslock
2049/tcp  open  nfs
2121/tcp  open  ccproxy-ftp
3306/tcp  open  mysql
5432/tcp  open  postgresql
5900/tcp  open  vnc
6000/tcp  open  X11
6667/tcp  open  irc
8009/tcp  open  ajp13
8180/tcp  open  unknown
MAC Address: 08:00:27:04:61:14 (PCS Systemtechnik/Oracle VirtualBox virtual NIC)

Nmap done: 1 IP address (1 host up) scanned in 0.66 seconds

```

```

(kali㉿kali)-[~/Desktop/Cyberster/week02]
$ sudo nmap -sS --source-port 53 192.168.0.110
Starting Nmap 7.95 ( https://nmap.org ) at 2026-03-13 10:25 EDT
Nmap scan report for 192.168.0.110
Host is up (0.00049s latency).
Not shown: 977 closed tcp ports (reset)
PORT      STATE SERVICE
21/tcp    open  ftp
22/tcp    open  ssh
23/tcp    open  telnet
25/tcp    open  smtp
53/tcp    open  domain
80/tcp    open  http
111/tcp   open  rpcbind
139/tcp   open  netbios-ssn
445/tcp   open  microsoft-ds
512/tcp   open  exec
513/tcp   open  login

```